

Incident Report Analysis

Incident: ICMP Flood Denial-of-Service Attack — Internal Network | Prepared by: Stacey Munnik

Summary (NIST CSF Functions)

Identify	The affected asset is the availability of the internal network, protected at the perimeter by a firewall that had not been configured to limit or filter ICMP traffic. Post-incident investigation confirmed a malicious actor sent a high-volume flood of ICMP echo request (ping) packets into the network; because no rule limited or filtered this traffic, the flood exhausted network resources for two hours, blocking normal internal traffic from reaching any network resource. This identifies the unconfigured firewall as the vulnerability and overall network availability — not any single server or application — as the asset impacted.
Protect	No protective control was in place to limit the rate or volume of incoming ICMP traffic before the incident, and there was no source-IP verification to catch spoofed packets — this gap is what let the flood through unchecked. Following the incident, the network security team implemented a firewall rule limiting the rate of incoming ICMP packets and enabled source IP address verification to reject spoofed traffic. Recommended additional protections: a recurring firewall/network device configuration audit (e.g., quarterly) so a gap like this is caught proactively, and network segmentation so a flood affecting one segment cannot exhaust resources needed by critical systems.
Detect	The incident was detected reactively — noticed only once network services stopped responding and employees reported being unable to reach resources — rather than through proactive monitoring. Following the incident, the team deployed network monitoring software to detect abnormal traffic patterns and an IDS/IPS system to filter ICMP traffic based on suspicious characteristics such as abnormal packet rate or a high volume from a single source. Configuring threshold-based alerting on these tools, so a spike like this triggers a notification within minutes rather than being discovered through service failure, would materially improve detection time for a future incident of this type.
Respond	Upon discovering that network services were unresponsive, the incident management team immediately blocked incoming ICMP packets and took non-critical network services offline to preserve capacity for critical systems, then restored critical services. The cybersecurity team investigated and traced the root cause to the unconfigured firewall that allowed the ICMP flood through. For future incidents, this response should be formalized into a documented playbook covering containment (rate-limit or block the offending traffic type), neutralization (identify and block the specific source IP address(es)), and analysis (preserve firewall logs and traffic captures from the incident window) — with escalation roles defined in advance rather than decided in the moment.
Recover	Recovery steps: (1) confirm the new ICMP rate-limiting and source-IP verification rules are correctly applied and that flood traffic has stopped; (2) restore remaining non-critical services in a controlled, prioritized order once the network is confirmed stable; (3) validate that no data was altered or lost during the outage, since a DoS attack affects availability rather than data integrity; (4) monitor closely for any recurrence in the days following recovery; (5) update the organization's incident response documentation to reflect the new firewall rules and monitoring tools, so recovery is faster if a similar flood occurs again.

Reflections/Notes

This incident reinforced that an availability failure can stem from a single missing configuration rather than a sophisticated exploit — the entry point here was simply a firewall rule that was never set, not a flaw in any application or service. Mapping the response to the NIST CSF functions made clear that this was primarily a Protect and Detect gap: the organization's Respond and Recover actions during the incident were reasonably effective, since critical services were restored within two hours, but there was no rate-limiting, no spoofed-IP filtering, and no proactive monitoring in place beforehand — which is why the flood was allowed to escalate into a full outage rather than being caught and blocked early.